YOUR GOALS OUR PRIORITY

FINANCEFIRST

CREDIT UNION

Lessons Learned and Improvement Plans

Version: 1.0

Effective Date: 12. December 2025

Owner: Incident Response Manager

Table of Contents

1. **Purpose:** 2
2. **Lesson Learned** 2
3. **Improvement Plan: Immediate, Short-Term, Long-Term** 3
4. **Metrics and KPIs** 7
5. **Conclusion** 7

1. Purpose:

The purpose of this document is to summarize the lessons learned from recent security incident and outline the actions taken by FinanceFirst Credit Union during the response and recovery process. It also provides a comprehensive improvement plan which includes immediate, short-term, and long-term actions, designed to strengthen the organization's resilience, enhance security posture and improve future incident response capabilities.

2. Lesson Learned

2.1. Root Cause Analysis (Five Whys)

Primary Question: Why did the ransomware attack succeed?

Step	Why?	Answer/Explanation
1	Why did the attack succeed?	Employee clicked a malicious phishing link.
2	Why did the employee click the link?	Email security controls did not block or detect the phishing email and training was insufficient.
3	Why did email and user controls fail?	Security awareness training was inadequate, phishing simulations were limited.
4	Why did lateral movement continue for 3 weeks undetected?	Weak network segmentation, no PAM, and SIEM rules missed reconnaissance activity.
5	Why were systemic weakness present?	IR Plan was untested, backups were not isolated, and the overall security program was still maturing.

Core Root Causes

- Insufficient phishing/email security controls
- Weak network segmentation, no privileged access management
- SIEM alerting gaps enabling 3 weeks of undetected activity
- Backups not immutable or isolated
- Incident response plan untested, roles unclear.

2.1. Timeline of Major Events

- Week 1-3: Attacker moves laterally between systems undetected.
- Day 22: Ransomware launched after prolonged reconnaissance.
- Same Day: IR team detects anomalous activity, isolates infected systems, performs password resets, block C2.
- Next 48 hours: Forensic team engaged. Eradication and recovery begin.
- Within 72 hours: Core banking and member services restored using offline backups.

2.2. What Worked Well

- Core banking system remained isolated and unaffected.
- Cloud-based online/ mobile banking remained operational.
- Containment actions were rapid and effective.
- Executive leadership provided strong support and resources.
- Forensic experts improved visibility into attacker actions.
- Logging and evidence were completed and well preserved.

2.3. What Didn't Work Well

- Phishing email bypassed email security gateway.
- No SIEM rules for PowerShell abuse, lateral movement, or beaconing.
- No PAM, privileged access exposed.
- Flat network allowed rapid lateral movement
- Backups were accessible from production network, no immutability.
- IR Plan was untested, uncertainty in roles and communication
- No formal crisis communication plan.

3. Improvement Plan: Immediate, Short-Term, Long-Term

3.1. Immediate Actions (0-30 Days)

Goal: Address urgent security gaps, update IR capabilities, and implement quick wins.

No.	Recommendation	Description& Justification	Responsible Party	Timelines & Milestones	Resources Required	Success Metrics

1	Implement emergency phishing controls	Block malicious domains, tighten email filters, deploy attachment sandboxing. This prevents recurrence of entry vector	IT Security	Day 1-7	Moderate	100% malicious email detection, no new phishing compromise
2	Update IR Plan & Clarify roles	IR Plan was untested and roles unclear. Update escalation paths and communication workflow	Risk and Compliance	Days 1-14	Minimal	IR Plan approved, staff acknowledgement, successful tabletop.
3	Conduct immediate staff retraining	Mandatory phishing and security refresher. Addresses root cause.	HR & IT	Days 1-30	Low	< 5% phishing test failure rate
4	Isolate/secure backup environment	Ensure backups are offline or immutable to prevent reinfection	IT Operation	Days 1-30	Moderate	Backups fully isolated, verified recovery.

3.2. Short-Term Actions (1-6 months):

Goal: Strengthen architecture, refine processes, enhance monitoring and build capability.

No.	Recommendation	Description& Justification	Responsible Party	Timelines & Milestones	Resources Required	Success Metrics
5	Deploy Privileged Access Management (PAM)	Prevents attackers from escalating privileges or stealing admin credentials.	IT Security	90 Days	High	100% admin accounts on boarded to PAM
6	Implement Network segmentation	Stop lateral movements by separating critical/non-critical systems	Infrastructure team	120 Days	High	Segmentation map complete, successful network isolation test.
7	Enhance SIEM rules and detection coverage	Add rules for reconnaissance, PowerShell abuse, lateral movement	Security Engineering	1-4 Months	Moderate	MTTD< 1 hour, zero missed alerts.
8	Formalize vulnerability and patch management	Routine scanning, prioritized patch cycles, configuration governance.	IT Operations	2-6 months	Moderate	95% patch compliance within SLA
9	Conduct IR tabletop exercises	Improve readiness, validate updated plan, train leadership	Risk & Compliance	Every 6 months	Low	Successful tabletop, reduced MTTR and MTTC

3.3. Long-Term Actions (6-12 months):

Goal: Build strategic security capability, mature governance, and strengthen resilience.

No.	Recommendation	Description& Justification	Responsible Party	Timelines & Milestones	Resources Required	Success Metrics
10	Implement zero-trust architecture	Long-term strategic control to limit unauthorized access and tighten trust boundaries	CISO and Security Architecture	6-12 months	High	Zero-Trust roadmap in place, phased rollout complete
7	Establish formal crisis communication plan	Ensure coordinated communication with regulators, member, media	Executive leadership and Legal	6-9 months	Low	Approved plan tested during tabletop
8	Invest in XDR/Advanced EDR	Modern endpoint visibility to detect covert attacker activity	Security engineering	6-12 months	High	Endpoint coverage 100% improved detection and response
9	Mature backup and resilience strategy	Fully immutable backup, offsite replication, regular testing	IT Operations	6-12 months	Moderate	100% backup success, quarterly recovery tests passed.
10	Advanced organizational cyber maturity	Align with NIST CSF maturity targets,	CISO	6-12 months	Moderate	Maturity level increase in independen

		formalize governance				t assessment

4. Metrics and KPIs

Metric	Target	Notes
Mean Time to Detect (MTTD)	<1 hour	Requires SIEM /XDR improvements
Mean Time to Respond (MTTR)	<2 hours	Faster containment and IR activation
Mean Time to Contain (MTTC)	<4 hours	Faster network isolation
Mean Time to Recover (MTTR)	48-72 hours	Based on tested backup capability
IR Plan Testing Frequency	Bi-annual	Leadership and CSIRT tabletop
Security Awareness Completion	100% annually	Phishing failure < 5%

5. Conclusion

The ransomware incident exposed critical gaps across FinanceFirst's security controls, monitoring, preparedness and governance. However, the incident also demonstrated that strong leadership, proper evidence handling, and resilient core systems enabled rapid recovery. This improvement plan provides a structured roadmap for enhancing defenses, maturing security capabilities and preventing recurrence. Implementing this actions will significantly strengthen FinanceFirst Credit Union's ability to detect, contain and recover from future incidents.